turknet

2026-27 GÜZ DÖNEMİ · SEÇMELİ LİSANS DERSİ

Güvenli Kodlama ve Programlama

Hafta 1 · Tanışma ve temel kavramlar



Can Öztaş

canoztas.github.io/courses/secure-coding

PROGRAM

Bu ders hangi kapsamda veriliyor?

T.C. Sanayi ve Teknoloji Bakanlığı

Turknet

İstanbul Nişantaşı Üniversitesi

Karamanoğlu Mehmetbey Üniversitesi

BUGÜN

Bu derste ne yapacağız

01	**Tanışma**	Eğitmen ve öğrenciler; kimin hangi konuda deneyimi var.
02	**Dersin çerçevesi**	Haftalık plan, notlandırma, dönem projesi, etik kurallar.
03	**Siber güvenlik temelleri**	Threat actor, attack, defense; vulnerability, exploit, risk, trust boundary, CVE/CWE/CVSS.
04	**İlk kod**	Beş satırlık bir Flask fonksiyonunda SQL injection.

TANIŞMA

Hadi tanışalım

R. Can Öztaş



TANIŞMA

Şimdi sizi tanıyalım

1. **Siber güvenliğe merakınız ve ilginiz**

   Nereden geliyor? CTF, haber, bir olay, bir hoca, sadece merak?

2. **Programlama ve geliştirme geçmişiniz**

   Hangi diller, ne tür projeler; okul ödevi mi, gerçek kullanıcıya giden kod mu?

3. **Bu dersten beklentileriniz**

   Ne öğrenmiş olarak çıkmak istiyorsunuz? Kariyer, CTF, staj, araştırma?

ÇERÇEVE

Bu ders ne, ne değil

Bu ders

- Kodun nasıl exploit edildiğini anlamak
- Root cause'u koddaki satıra kadar takip etmek
- Kontrolleri tasarıma ve koda eklemek
- Dil ve framework'ten bağımsız ilkeler

Bu ders değil

- Pentest sertifika kursu
- Tek bir aracın kullanım eğitimi
- Tek bir dile bağlı bir ders
- Ezberlenecek bir payload listesi

Çalışan kod, güvenli kod demek değildir.

Testler kodun beklenen girdilerle doğru çalışıp çalışmadığını kontrol eder. Saldırgan ise beklenmeyen girdilerle kodun başka ne yaptığına bakar.



ÇERÇEVE

Dönem sonunda ne yapabileceksiniz

Exploit	Yaygın vulnerability sınıflarını izole bir lab ortamında tetiklemek.
Code review	Bir kod parçasında trust boundary'leri ve riskli noktaları bulmak.
Fix	Root cause'u kapatan düzeltmeyi yazmak.
Triage	SAST ve DAST bulgularını yorumlamak, false positive'leri ayırmak.
Gerekçelendirme	Bir tasarım kararını güvenlik gerekçesiyle ekibe anlatmak.

YÖNTEM

Önce saldırgan, sonra savunma

1 · Exploit

Vulnerability'yi kendi lab ortamınızda tetikleyin.

2 · Root cause

Hangi varsayım yanlıştı? Sorun hangi satırda, hangi tasarım kararında?

3 · Fix

Aynı sınıftaki hataları da kapatan yapısal düzeltmeyi yazın.

PLAN

Haftalık plan · 1-8

Hafta	Konu
1	Giriş, secure design ilkeleri ve threat modeling
2	Injection: SQL injection, command injection ve path traversal
3	Browser security model, XSS ve CSRF
4	Applied cryptography
5	Authentication, parola saklama ve session management
6	Authorization, access control ve API security
7	C/C++ ve memory safety
8	Secure configuration, logging, supply chain ve CI/CD

PLAN

Haftalık plan · 9-15

Hafta	Konu
9	SAST/DAST ile vulnerability tespiti ve triage
10	AI-assisted development güvenliği
11	LLM application security
12	Tampon: geriden gelen konular ve uygulama
13	Tampon: uygulama ve bütünleşik tekrar
14	Genel tekrar
15	Final sınavı

ÇERÇEVE

Notlandırma

%60

Final sınavı

Dönem sonu; kod okuma ve gerekçelendirme ağırlıklı.

%20

Vize

%20

Dönem projesi

Bireysel Zafiyet Otopsisi: gerçek bir CVE'nin root cause'u, exploitation yolu ve patch analizi; teknik rapor ve kısa video.

Sınav tarihleri üniversitelerin akademik takvimine göre ders sayfasında duyurulur.

DÖNEM PROJESİ

Dönem projesi: Zafiyet Otopsisi

Her öğrenci haftalık konularla eşleşen, patch'i yayımlanmış gerçek bir vulnerability'yi (CVE ya da bilinen bir olay) listeden seçer ve kaynak koduna kadar inceler.

Vulnerable code

Hatalı kod parçası ve root cause.

Exploitation

Saldırgan bu hatayı hangi adımlarla kullanıyor?

Patch analizi

Patch root cause'u mu kapatıyor, yalnızca bir belirtiyi mi?

Dersle bağ

Hangi hafta, hangi pratik bunu engellerdi?

Proje bireyseldir. Teslim: teknik rapor ve **en fazla 5 dakikalık** anlatım videosu; ders saatinde sunum yapılmaz.

KURALLAR

Etik ve yasal çerçeve

Yazılı izin olmadan test yok

Sahibi olmadığınız ve test izni almadığınız sistemlere istek göndermeyin.

Lab ortamı

Tüm uygulamalar yerel, izole ve kasıtlı olarak vulnerable bırakılmış ortamlarda yapılır.

Yasal zemin

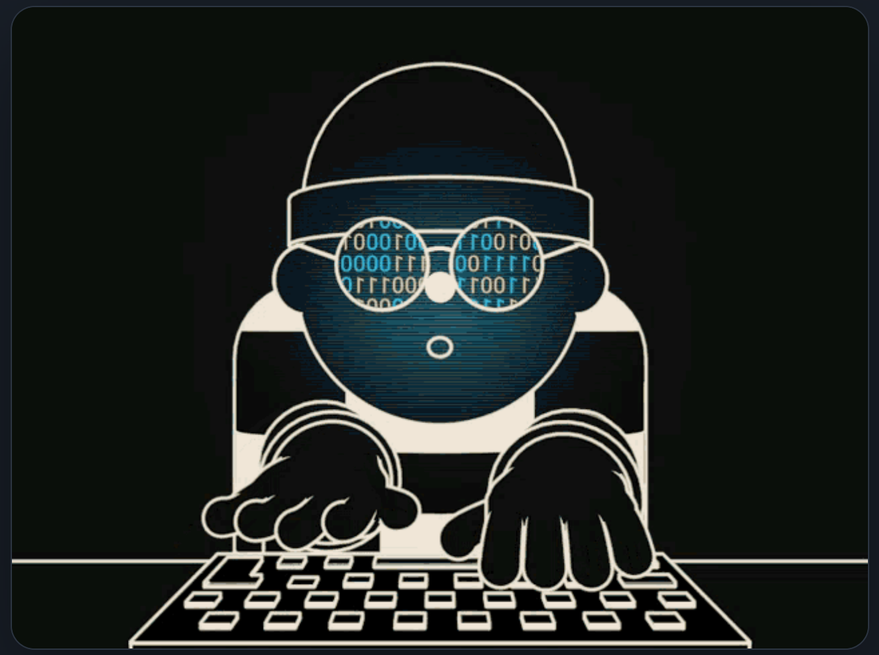
Türk Ceza Kanunu 243-245: bilişim sistemine izinsiz girmek, sistemi engellemek ve veriyi bozmak suçtur.

Responsible disclosure

Gerçek bir vulnerability bulursanız önce üreticiye bildirin; yayımlamadan önce benimle konuşun.

BÖLÜM 2

Siber güvenlik temelleri



TEMELLER

Threat actor’lar ve amaçları

Script kiddie

Hazır araçlar ve otomatik taramalar kullanır; belirli bir hedef seçmez.

Hacktivist

Politik veya ideolojik amaçlıdır: defacement, veri sızdırma, DDoS.

Cybercrime grupları

Finansal amaçlıdır: ransomware, kart verisi, account takeover.

Insider threat

Meşru erişimi olan çalışan veya tedarikçi; kötü niyet ya da ihmal.

APT (devlet destekli)

Uzun süreli, hedefli operasyonlar: casusluk, sabotaj, supply chain saldırıları.

Security researcher

İzinli test yapar; bulguları responsible disclosure veya bug bounty ile bildirir.

Threat modeling'de bu ayrımı kullanırız: hangi aktör, **hangi varlığa, hangi yoldan** ulaşmak ister?

TEMELLER

White hat, gray hat, black hat

White hat

Yazılı izinle test eder, bulguyu sistem sahibine bildirir. Pentester, security researcher, bug bounty katılımcısı.

Gray hat

İzin almadan test eder; sonra bildirir, ücret ister ya da ifşa eder. İzinsiz erişim, niyetten bağımsız olarak suçtur.

Black hat

Kazanç, zarar veya casusluk için izinsiz erişim sağlar. Cybercrime ve ransomware grupları.

Green hat

Alana yeni başlayan; CTF'lerde ve topluluklarda öğrenir.

Blue hat

İki kullanımı var: ürün yayımlanmadan önce davetle test eden dış uzman (Microsoft BlueHat) veya intikam amaçlı saldırgan.

Red hat

Black hat'lere karşı izinsiz, saldırgan yöntemler kullanır. Amaç savunma olsa da yöntem yasa dışıdır.

Araçlar ve teknikler çoğu zaman aynıdır; ayrımı **izin ve amaç** belirler.

TEMELLER

Bir saldırının aşamaları

01

Reconnaissance

Alan adları, çalışanlar, yazılım sürümleri, açık portlar.

02

Initial access

Phishing, sızdırılmış parola, internete açık servisteki vulnerability.

03

Execution

Exploit, makro, malware veya web shell ile kod çalıştırma.

04

Persistence ve privilege escalation

Erişimi kalıcı hâle getirme; kullanıcı yetkisinden admin yetkisine geçiş.

05

Lateral movement

Ele geçirilen makineden ağdaki diğer sistemlere geçiş.

06

Actions on objectives

Veri sızdırma, ransomware ile şifreleme, sabotaj veya uzun süreli izleme.

Aşamalar **Cyber Kill Chain** (Lockheed Martin) ve **MITRE ATT&CK** tactic'lerinden sadeleştirildi. Uygulamadaki bir vulnerability çoğunlukla 02 ve 03'te kullanılır.

TEMELLER

Defense in depth katmanları

People & process

Security awareness, parola politikası, incident response planı.

Network

Segmentation, firewall, TLS, zero trust.

Endpoint

Güncel patch'ler, EDR, least privilege ile çalışan servisler.

Application

Input validation, güvenli kütüphaneler, code review, SAST/DAST.

Data

Encryption, backup, access log, data minimization.

Defense in depth

Tek bir kontrol aşılabilir; bir katmanın açığını diğeri sınırlar.

Assume breach

Saldırganın içeride olduğu varsayılır: erişim sınırlı, hareket izlenebilir olmalı.

Asymmetry

Saldırgana tek bir açık yeter; savunma bütün giriş noktalarını kapsamalı.

Bu ders **Application** katmanına odaklanır. Diğer katmanlar etkiyi sınırlayabilir, koddaki vulnerability'yi ise ortadan kaldırmaz.

TEMELLER

CTF nedir?

Capture The Flag (CTF): kasıtlı olarak vulnerable bırakılmış sistemlerde flag bulma yarışması. İki format: **Jeopardy** (kategorilere ayrılmış bağımsız challenge'lar) ve **Attack–Defense** (takımlar kendi servislerini korurken rakip servislere saldırır).

WEB

XSS, SQLi, authentication hataları. Bu dersin konularının çoğu.

PWN / BINARY

Memory corruption, buffer overflow, ROP. 7. hafta.

REVERSE

Kaynak kodu olmayan bir binary'yi analiz etmek.

CRYPTO

Yanlış kullanılan kriptografiyi kırmak.

FORENSICS / OSINT

Disk imajı, ağ trafiği ve log analizi; açık kaynaklardan bilgi toplama.

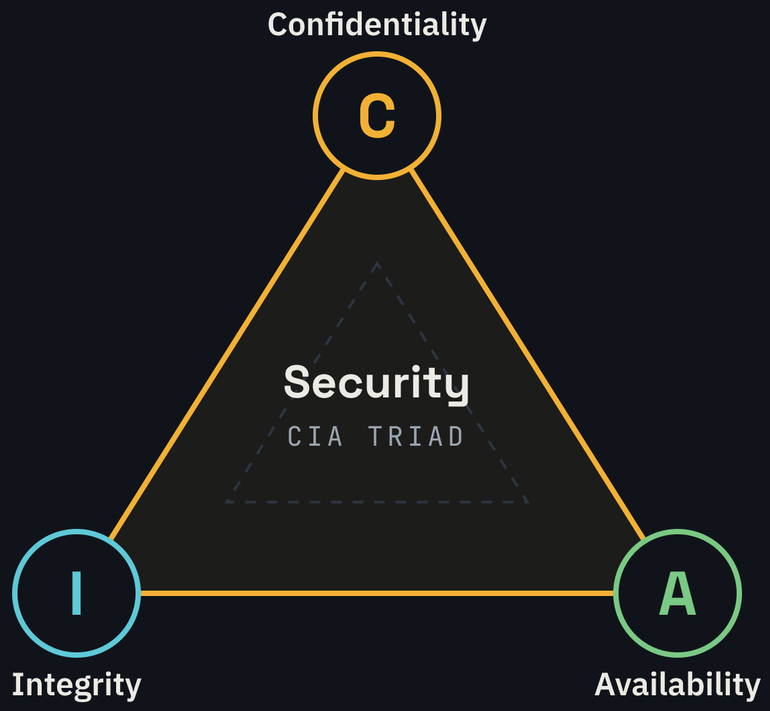
MISC

Diğer kategorilere girmeyen challenge'lar.

Başlangıç için: **picoCTF**, **PortSwigger Web Security Academy**, **TryHackMe**, **Hack The Box**; takvim için **ctftime.org**.

KAVRAM

CIA triad



Confidentiality

Veriyi yalnızca yetkili taraflar görebilir. İhlal edilirse: data breach.

Integrity

Veri yalnızca yetkili yollarla değişir. İhlal edilirse: bakiye, rol ya da fiyat yetkisiz değişir.

Availability

Sistem ihtiyaç duyulduğunda çalışır. İhlal edilirse: hizmet durur.

CIA ile birlikte iki soru sorulur: kullanıcının **kim olduğunu** nasıl biliyoruz (authentication) ve **neye erişebileceğini** nasıl belirliyoruz (authorization)?

KAVRAM

Bug, vulnerability, exploit

Terim	Ne demek	Örnek
Bug	Beklenen davranıştan sapma.	Sayfa 500 hatası veriyor.
Vulnerability	Bir güvenlik sınırını aşmaya izin veren bug.	Girdi doğrudan SQL sorgusuna giriyor.
Exploit	Vulnerability'yi tetikleyen somut girdi ya da kod.	id=1 OR 1=1
Payload	Exploit başarılı olduğunda çalışan kısım.	Kullanıcı tablosunu dışarı aktar.
Zero-day / n-day	Zero-day: henüz patch'i olmayan vulnerability. N-day: patch'i yayımlanmış olan.	N-day: patch çıkmış ama uygulanmamış sistemler.

Her vulnerability bir bug'dır; her bug vulnerability değildir. Ayrım, hatanın bir güvenlik sınırını aşmaya izin verip vermediğidir.

KAVRAM

Risk nasıl hesaplanır

Risk ≈ Threat × Vulnerability × Impact

Threat

Kötüye kullanma niyeti ve kapasitesi olan taraf.

Vulnerability

Bu tarafın kullanabileceği zayıflık.

Impact

Exploit edilirse ne kaybedilir?

Attack surface

Dışarıdan ulaşılabilen giriş noktalarının toplamı.

Formül yaklaşık bir modeldir. Secure coding vulnerability çarpanını düşürür; mimari kararlar attack surface'i küçültür.

KAVRAM

Trust boundary

UNTRUSTED

Tarayıcı, mobil uygulama, API client

Kontrol kullanıcıdadır. Client-side validation atlanabilir.

TRUSTED

Sunucu, business logic, veritabanı

Güvenlik kararları burada verilir; validation burada zorunludur.

Boundary'yi geçen her şey input'tur: form alanı, header, cookie, dosya adı, başka bir servisin JSON yanıtı, veritabanındaki eski bir kayıt. **Doğrulanana kadar untrusted kabul edilir.**

KAVRAM

CVE, CWE, CVSS

Kısaltma	Ne işe yarar	Örnek
CVE	Belirli bir üründeki belirli bir vulnerability'nin kimliği.	CVE-2021-44228
CWE	Vulnerability türü (weakness sınıfı).	CWE-89: SQL injection
CVSS	0–10 arası severity puanı.	9.8 (Critical)
OWASP Top 10	En yaygın web uygulaması risk kategorileri.	A01: Broken Access Control
KEV	CISA'nın, aktif olarak exploit edildiği doğrulanan vulnerability kataloğu.	Patch önceliklendirme

CVSS base score ortamınızı bilmez: Critical puanlı bir vulnerability sizin mimarinizde erişilemez olabilir, Medium puanlı biri sizin için kritik olabilir.

UYGULAMA

Beş satır, iki soru

```
@app.route("/profile")
def profile():
    uid = request.args.get("id")
    q = "SELECT name, email FROM users WHERE id = " + uid
    return db.execute(q).fetchone()
```

Test

id=1 ile beklenen kaydı döndürüyor mu? Döndürüyor; test geçer.

Security review

id sayı değilse ne olur? Bu kod, id ile gelen metni SQL'in parçası yapar.

UYGULAMA

Aynı kod, saldırganın gözüyle

```
GET /profile?id=1
GET /profile?id=1 OR 1=1
GET /profile?id=1 UNION SELECT password_hash, NULL FROM users
```

Root cause

Kullanıcı girdisi SQL metnine string olarak ekleniyor. Veritabanı, id değerinin nerede bittiğini ve SQL'in nerede başladığını ayırt edemiyor.

Fix: parameterized query

SQL metni sabit kalır; id değeri ayrı bir parametre olarak bağlanır. Manuel escaping bu ayrımı sağlamaz.

2. haftada bu örneği adım adım işleyeceğiz; aynı kalıbı command injection ve path traversal'da da göreceğiz.

İLKELER

Saltzer ve Schroeder, 1975

Least privilege

Her bileşen işini yapmaya yetecek en dar yetkiyle çalışsın.

Fail-safe defaults

Varsayılan karar reddetmek olsun; erişim açıkça verilsin.

Complete mediation

Her erişim, her seferinde kontrol edilsin.

Open design

Güvenlik tasarımın gizli kalmasına dayanmasın; gizli olan anahtar ve parolalar olsun.

Economy of mechanism

Tasarım küçük ve basit olsun; incelenemeyen kod doğrulanamaz.

Psychological acceptability

Kullanımı zor olan kontroller kullanıcılar tarafından atlatılır.

İLKELER

Güvenlik ne zaman düşünülür?

Design	Development	Review	Test / CI	Operations
Threat modeling	Secure coding	Code review	SAST, DAST, dependency scanning	Logging, monitoring, patching

Güvenlik her aşamada ele alınır. Bir hata ne kadar geç bulunursa düzeltmesi o kadar pahalıdır. Kontrolleri erken aşamalara taşımaya **shift-left** denir.

KAYNAKLAR

Dönem boyunca başvuracağınız kaynaklar

STANDARTLAR VE REHBERLER

- OWASP Top 10 (2025)
- OWASP Top 10 for LLM Applications
- OWASP Application Security Verification Standard (ASVS)
- OWASP Cheat Sheet Series
- SEI CERT Secure Coding Standards

ÖNERİLEN KİTAPLAR

- Mathias Payer, *Software Security: Principles, Policies, and Protection* (SS3P) — nebelwelt.net/SS3P
- Robert C. Seacord, *Secure Coding in C and C++*, 2. Baskı, Addison-Wesley, 2013
- Dan Bergh Johnsson, Daniel Deogun & Daniel Sawano, *Secure by Design*, Manning, 2019
- Adam Shostack, *Threat Modeling: Designing for Security*, Wiley, 2014
- Dafydd Stuttard & Marcus Pinto, *The Web Application Hacker's Handbook*, 2. Baskı, Wiley, 2011
- Michael Howard & David LeBlanc, *Writing Secure Code*, 2. Baskı, Microsoft Press, 2003

EK KAYNAKLAR

- OpenSSF, Developing Secure Software (LFD121) — training.linuxfoundation.org
- Stanford CS 253 Web Security — web.stanford.edu/class/cs253

Tam liste ve bağlantılar ders sayfasında: **canoztas.github.io/courses/secure-coding**

KAPANIŞ

Haftaya kadar şunlara bakın

Burp Suite

Community Edition'ı kurun; kendi tarayıcı trafiğinizi proxy üzerinden izleyip HTTP request/response yapısını inceleyin.

Web security temelleri

OWASP Top 10 listesini okuyun; HTTP, cookie ve session kavramlarını tekrar edin.

Stanford CS 253

Web Security ders konularına bakın: browser security model, XSS, CSRF.

Haftaya: **SQL injection, command injection ve path traversal**; threat modeling ile başlayacağız.

SORU · CEVAP

Sorular?

